

SECTION A

1. Matching

a. “It will come from the portfolio which has been created to support the IS strategy, and a feasibility study might be used to evaluate the approach, and the results included in the business case.”

Answer: 7. Need for the project

b. “Determine any strengths the team lacked, along with strengths they demonstrated.”

Answer: 5. Conduct a gap analysis

c. “A key benefit of conducting information system reviews”

Answer: 1. Regulatory Compliance

d. “It determines whether to authorize a current project to proceed to the next stage.”

Answer: 8. Gate review

e. “It is essential in creating Service Level Agreements (SLAs) and Service Level Objectives (SLOs), as well as in determining the costs of service delivery.”

Answer: 2. Service Level Management

f. “It lays out specifics of how each control area fits into the overall information security program.”

Answer: 4. Standard

g. “They are tools and protocols used for identification, authentication, authorization, and accountability in computer information systems.”

Answer: 6. Logical access controls

h. “Secures individual devices (e.g., laptops, smartphones) to prevent malware and unauthorized access.”

Answer: 3. Endpoint Security

Final matching answer: a–7, b–5, c–1, d–8, e–2, f–4, g–6, h–3

2. Multiple Choice

i. Processes for gathering and analyzing project data to keep costs and schedules on track.

B. Project controls ✓

Why: Project controls monitor project information, especially cost and schedule, to keep the project on track.

ii. Step involved in implementation process of MIS

C. Change over ✓

Why: Changeover is the stage where the organization moves from the old system to the new system.

iii. It involves the use of feedback and performance data to drive ongoing enhancements in service quality.

Answer: A — Continuous Improvement

Why: Continuous improvement means continually using performance information and feedback to improve service quality.

iv. Practices essential for overseeing relationships with external organizations that provide services/products.

Answer: D — Third-party management

Why: Third-party management deals with organizations outside the company that provide services or products.

v. Tracking how well users are able to use the system and identifying areas where improvements can be made.

D. Performance monitoring ✓

vi. Activity that must be monitored during Application Monitoring.

Answer: A — Resource usage

Why: Application monitoring checks things such as application status, resource usage and abnormal behavior.

vii. Usernames/passwords, two-factor authentication, antivirus software and firewalls.

Answer: C — Digital security controls

viii. Those that must work in order to have data and information available.

Answer: B — Secondary information assets

Why: Secondary/supporting information assets such as hardware, software, people and infrastructure support the availability and use of primary information assets.

3. SHORT ANSWERS

i. What is the use of the benefits realization process?

Answer:

The benefits realization process is used to ensure that the expected benefits of an information system project are actually achieved after or during implementation.

Examples of benefits include:

Reduced costs.

Improved efficiency.

Better service delivery.

Improved decision-making.

ii. What is the role of a project team leader?

Answer:

A project team leader is responsible for coordinating and guiding the project team so that project objectives are achieved.

Main roles include:

Assigning tasks.

Coordinating team members.

Monitoring project progress.

Communicating with stakeholders.

Identifying and managing problems.

Ensuring work is completed according to the project plan.

iii. What is System Operation and Maintenance?

Answer:

System operation and maintenance is the process of operating, supporting, repairing, updating and maintaining an information system so that it remains reliable, efficient, secure and useful.

iv. Mention one common methodology for conducting information system reviews.

Answer:

One common methodology is interviewing.

Other acceptable answers include:

Checklists.

Documentation review.

Observation.

Testing.

Benchmarking.

The exam specifically asks for one.

v. What is the purpose of Incident Management?

Answer:

The purpose of Incident Management is to restore normal IT service as quickly as possible after an incident while minimizing its impact on the organization.

Example: If a university's student registration system stops working, incident management focuses on restoring the system quickly.

vi. Mention two basic types of information security policy.

Answer:

Any two:

1. Program Policy

2. Issue-Specific Policy

3. System-Specific Policy

For two marks, write any two and briefly identify them.

vii. Give a brief description of the term "Procedure".

Answer:

A procedure is a step-by-step set of instructions explaining how a particular task or security requirement should be carried out.

Easy memory:

Policy = WHAT

Standard = REQUIREMENT

Procedure = HOW

viii. Define Logical Access Controls.

Answer:

Logical access controls are technical controls used to identify, authenticate, authorize and maintain accountability for users accessing computer information systems.

Examples include:

Username and passwords.

Biometrics.

Two-factor authentication.

Access permissions.

This definition closely matches the wording used in the exam.

SECTION B

QUESTION 1

a) Describe clearly the purpose of project review. (3 marks)

Answer:

The purpose of a project review is to evaluate the progress and performance of a project and determine whether it is achieving its objectives.

The main purposes are:

- 1. Identify problems — find problems affecting the project and take corrective action.**
- 2. Measure project success — determine whether objectives, time, cost and quality requirements have been achieved.**
- 3. Identify lessons learned — determine what worked well and what should be improved in future projects.**

b) Give a detailed description of the project review process. (9 marks)

Answer:

The project review process can be described as follows:

1. Plan the review

Determine the purpose, scope, objectives and areas to be examined.

2. Form the review team

Select appropriate people such as a review leader, data analyst and note taker.

3. Collect information

Collect project documents, schedules, budgets, reports, metrics and other evidence.

4. Interview stakeholders

Talk to project team members, managers, users and other relevant stakeholders.

5. Analyze project performance

Evaluate:

Cost.

Time.

Quality.

Methodology.

Risks.

Resources.

Project objectives.

6. Conduct gap analysis

Determine the strengths and weaknesses of the project team, processes and resources.

7. Identify problems and risks

Determine issues that have affected or may affect project success.

8. Discuss findings

Share findings with project stakeholders and allow them to provide explanations or feedback.

9. Prepare the project review report

Document findings, conclusions, recommendations and lessons learned.

Easy sequence to remember:

Plan → Team → Collect → Interview → Analyze → Gap → Risks → Discuss → Report

The exam specifically asks about the purpose and process of project reviews.

QUESTION 2

As an employee of ZRA, explain how you would use Project Review Best Practices to review their new tax collection system. (12 marks)

Answer:

If I were an employee of ZRA, I would conduct the review of the new tax collection system using the following project review best practices:

1. Review the project as a team

I would establish a review team containing people with appropriate technical, financial, auditing and project management knowledge.

2. Bring supporting documentation

I would collect important documents such as:

Project plan.

Budget.

Requirements.

System specifications.

Testing reports.

Implementation reports.

Risk register.

3. Ask meaningful questions

I would ask questions such as:

Was the system completed on time?

Was it completed within budget?

Does it meet ZRA requirements?

Are taxpayers able to use it effectively?

Are tax records secure?

Are there unresolved problems?

4. Interview team members individually

I would interview developers, project managers, users, administrators and other relevant staff to obtain honest information about the system.

5. Examine project performance

I would evaluate:

Cost.

Time.

Quality.

Scope.

Risks.

System performance.

User satisfaction.

6. Conduct gap analysis

I would identify weaknesses in:

Staff skills.

Technology.

Procedures.

Security.

Resources.

7. Review risks

I would identify security, operational, financial and implementation risks associated with the tax collection system.

8. Discuss results with stakeholders

I would present findings to ZRA management, project managers, technical staff and other stakeholders.

9. Prepare a review report

The report would contain:

Findings.

Problems.

Causes.

Recommendations.

Lessons learned.

10. Follow up

After recommendations are implemented, I would conduct a follow-up review to determine whether the identified problems have been corrected.

Conclusion: This approach would help ZRA determine whether its new tax collection system is meeting its objectives, operating effectively and providing the expected benefits.

The exam specifically frames this question around applying Project Review Best Practices to a new ZRA tax collection system.

QUESTION 3

a) Define Information System Reviews. (1 mark)

Answer:

An Information System Review is an evaluation of an organization's information system to determine whether it meets its operational, tactical and strategic business needs.

b) Benefits of conducting information system reviews. (4 marks)

- 1. Improved efficiency — identifies inefficient processes and systems.**
- 2. Enhanced security — identifies security weaknesses.**
- 3. Better decision-making — provides information about system performance.**
- 4. Regulatory compliance — ensures the organization follows relevant laws and regulations.**

Other benefits include cost savings and strategic alignment.

c) Common methodologies for conducting IS reviews. (3 marks)

The common methodologies include:

- 1. Checklists**
- 2. Interviews**
- 3. Documentation review**
- 4. Observation**
- 5. Testing**
- 6. Benchmarking**

d) How can you apply these methodologies during an IS review? (4 marks)

1. Checklists

Use a prepared checklist to systematically check whether required controls, procedures and standards exist.

2. Interviews

Interview users, managers and IT staff to understand how the system operates and identify problems.

3. Documentation review

Examine system manuals, policies, procedures, specifications and maintenance records to determine whether the system is properly documented.

4. Observation

Observe employees using the system to determine whether actual practices match documented procedures.

5. Testing

Perform appropriate tests to determine whether system controls and functions work as expected.

6. Benchmarking

Compare system performance with standards or similar organizations.

QUESTION 4

a) Describe in detail Service Level Management (SLM) practices. (4 marks)

Answer:

Service Level Management (SLM) is the practice of defining, agreeing, monitoring and managing the level and quality of IT services.

Important SLM practices include:

1. Define service levels

Establish clear service requirements and expected performance.

2. Monitor services

Continuously monitor whether the IT service meets agreed performance levels.

3. Report performance

Prepare reports showing actual performance compared with agreed service levels

4. Review agreements

Regularly review SLAs to ensure they still meet business requirements.

5. Manage relationships

Maintain good relationships between the service provider and customer.

6. Continuous improvement

Use feedback and performance information to improve service quality.

b) Define Service Level Agreements (SLAs). (2 marks)

Answer:

A Service Level Agreement (SLA) is a formal agreement between a service provider and a customer that defines the expected level, quality and performance of a service.

Example: An IT provider may agree that a system should be available 99.9% of the time.

c) Explain key components of SLAs. (6 marks)

1. Service description

Explains the services being provided.

2. Performance metrics

Defines how service performance will be measured.

3. Service standards

Specifies the expected level of service.

4. Monitoring and reporting

Explains how performance will be monitored and reported.

5. Problem management

Defines how service problems and incidents will be handled.

6. Consequences for non-compliance

Explains what happens if the provider fails to meet agreed requirements.

7. Review period

Specifies when the SLA should be reviewed and updated.

QUESTION 5

As a newly employed graduate, describe data classification processes and procedures you would advise your employer. (12 marks)

Answer:

Data classification is the process of categorizing information according to its sensitivity, importance and required level of protection.

I would advise the employer to use the following processes:

1. Identify the data

Identify all important information owned or used by the organization.

Examples:

Customer information.

Employee records.

Financial information.

Business plans.

2. Determine sensitivity

Determine how sensitive each type of information is.

For example:

Public information.

Internal information.

Confidential information.

Highly sensitive information.

3. Determine required protection

Decide what security controls each classification requires.

Sensitive data should receive stronger protection.

4. Collect only necessary information

The organization should avoid collecting unnecessary personal or sensitive information.

5. Apply access controls

Give users access according to their responsibilities.

This follows the principle of least privilege — users receive only the access necessary to perform their duties.

6. Control information sharing

Information should only be shared with authorized people and organizations.

7. Protect information during transmission

Sensitive data should be protected when being transferred over networks.

8. Protect physical equipment

Computers, servers, storage devices and other equipment containing sensitive data should be physically secured.

9. Protect stored information

Use appropriate controls such as:

Access controls.

Encryption.

Authentication.

Backups.

10. Secure disposal

When information is no longer required, it should be securely disposed of so unauthorized people cannot recover it.

11. Train employees

Employees should be trained to understand:

Data classifications.

Their responsibilities.

Proper data handling.

Security risks.

12. Regularly review classification

Data classifications should be reviewed and updated when business requirements, risks or information sensitivity change.

Conclusion: Proper data classification ensures that important information receives an appropriate level of protection while allowing authorized users to access information they need.

QUESTION 6

a) What are information assets and why are they important? (2 marks)

Answer:

Information assets are valuable information, data and supporting resources that are important to an organization.

They include:

Data.

Software.

Hardware.

People.

IT services.

Physical infrastructure.

Importance

They are important because organizations depend on them to perform operations, make decisions and provide services. Loss, theft, damage or misuse of information assets can cause serious organizational problems.

b) How can you divide information assets? (6 marks)

Information assets can be divided into two major categories:

1. Primary Information Assets

These are the actual data and information that have value to the organization.

Examples:

Customer records.

Financial information.

Employee records.

Business plans.

Login information.

2. Secondary/Supporting Information Assets

These are resources that support the creation, storage, processing or availability of primary information assets.

Examples:

Hardware.

Software.

People.

IT services.

Physical infrastructure.

Cloud storage.

c) How can you keep an information asset inventory? (4 marks)

Answer:

An information asset inventory is a maintained record/list of the organization's information assets.

To keep it properly:

1. Identify and record assets

Record all important information assets.

2. Record important details

Include information such as asset type, owner, sensitivity/confidentiality and dependencies.

3. Regularly update the inventory

Add new assets and remove assets that are no longer used.

4. Validate the inventory

Management and asset owners should regularly check that the inventory is accurate.